UNIVERSITI MALAYSIA SARAWAK (UNIMAS)
Faculty of Computer Science and Information Technology

Assignment/Report Cover Sheet

Student Name	Student ID Number	Signature
JENX YAP YEE XUAN	104527	*JENX*
CHAN KAR KAY	103618	*CHAN*
THEBAN A/L VEVINDRAN	106554	*THEBAN*
DIVESHWAR A/L SARAVANAN	103879	*DIVESHWAR*
EMMANUEL STEFHANIUS ANAK DENNIS	104008	*EMMANUEL*

Subject Code : TMN2073	**Subject Name : Computer security**
Project: AI/ML-Enhanced Multi-Factor Authentication to Mitigate Password Guessing Attacks	**Lecturer : Prof Madya Ts Dr Adnan Shahid Khan**
Date due: 25 May 2026	**Date Submitted : 25/5/2026**

This cover sheet must be completed, signed and firmly attached to the front of the submission. All work must be submitted by the due date. If an extension of work is granted, an assignment extension acknowledgement slip must be signed by the lecturer/tutor and attached to assignment. Please note that is your responsibility to retain copies of your assignment.

Plagiarism and Collusion are methods of cheating that falls under Peraturan Akademik Universiti Malaysia Sarawak para 11: Etika Akademik

Plagiarism
Plagiarism is the presentation of work which has been copied in whole or in part from another person's work, or from any other source such as the internet, published books or periodicals without due acknowledgement given in the text.

Collusion
Collusion is the presentation of work that is the result in whole or in part of unauthorized collaboration with another person or persons.

Where there are reasonable grounds for believing that cheating has occurred, the only action that may be taken when plagiarism or collusion is detected is for the staff member not to mark the item of work and to report or refer the matter to the Dean. This may result in work being disallowed and given a fail grade or if the circumstances warrant, the matter may be referred to a Committee of inquiry for investigation. Such investigation may result in the matter being referred to the University Discipline Committee, **which** has the power to exclude a student.

MARK :

Question 1: Problem Statement

By enabling attackers to constantly try numerous passwords until the correct one is found, password guessing attacks, such as brute-force and dictionary attacks, pose significant threats to contemporary authentication systems (Carrillo-Torres et al., 2023). Such attacks make use of the vulnerabilities in password-only authentication systems, which solely rely on user-selected credentials that are often weak or simple to figure out. The frequency of credential-related breaches, such as those brought on by weak or stolen passwords have underscored the limitations of conventional authentication methods, which lack comprehensive threat detection and adaptive response capabilities.

Given that password-only systems provide a single point of failure if an attacker is able to obtain or guess the password, they gain unrestricted access which in turn makes it particularly vulnerable. Furthermore, according to Papaspirou et al. (2024), these systems typically lack advanced detection methods that are able to identify suspicious patterns indicative of password guessing attempts. Attackers have the ability to persist with automated or AI-assisted attacks that can effectively crack passwords over time given that there is no preemptive defense.

Current multi-factor authentication (MFA) schemes do enhance security by demanding extra identity proofs in addition to having a password, such as biometric factors, tokens or graphical passwords. Still, some MFA systems still suffer from numerous vulnerabilities including but not limited to man-in-the-middle attacks, and password guessing attacks and hijacking sessions if not designed properly. Furthermore, some advanced MFA systems rely on specific hardware or infrastructure, which may not be practical or scalable in all situations.

A promising approach to these challenges is to include machine learning (ML) and artificial intelligence (AI) techniques into MFA systems. MFA systems incorporating AI/ML enhancements can dynamically analyze login attempts to identify irregularities and suspicious behaviour indicative of password guessing attacks. For instance, these structures can classify and respond to possible threats in real time by using intrusion detection models and adaptive cryptographic frameworks, which minimizes the risk of unauthorized access due to compromised credentials (Sasikumar & Nagarajan, 2025).

In conclusion, by allowing attackers to attempt a large number of password guesses, password guessing attacks exploit the inherent intrinsic flaw in password-only authentication. Traditional systems generally are vulnerable to these attacks because they lack intelligent detection and adaptive response mechanisms. By integrating additional authentication factors and leveraging intelligent algorithms that can identify and stop suspicious login attempts, AI/ML enhanced MFA approaches can greatly improve security and provide a more robust defense against ever changing cyberthreats.

Question 2 Proposed AI/ML-Enhanced MFA Solution and Algorithm Design

2.1 System Architecture Diagram

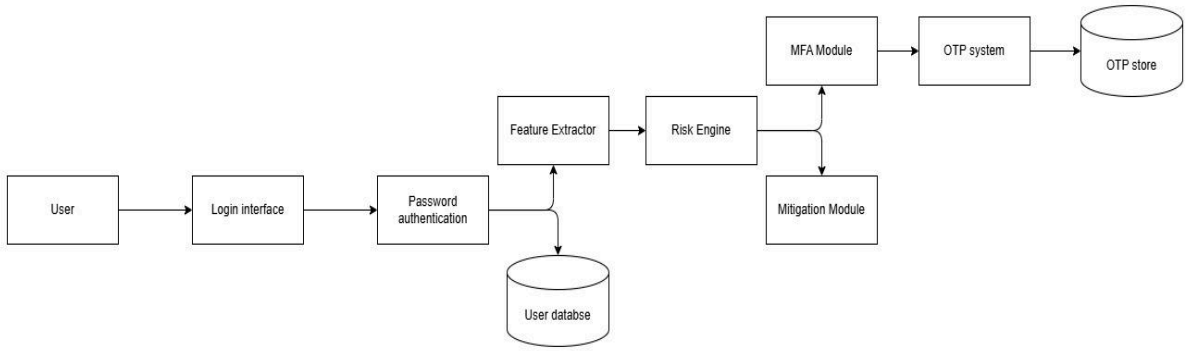


Figure 1: Architecture Diagram

2.2 System Component

2.2.1 Login Interface

The login interface represents the entry point of the authentication system. It enables users to provide the device details and login credentials required for risk analysis and authentication confirmation.

2.2.2 Password Authentication Layer

By comparing the entered username and password to the database's stored records (users.json or SQLite), the password authentication layer is responsible for verifying user credentials. Before any additional authentication processes are executed, credential matching is carried out. The system proceeds with risk analysis and MFA authentication if authentication is successful. If authentication fails, the attempt is recorded and added to the risk score used for identifying suspicious logins.

2.2.3 AI/ML Risk Detection Engine

The purpose of the AI/ML risk detection engine is to examine user login behaviour to identify suspicious authentication attempts that might point to password guessing attacks. The system analyzes a variety of factors including but not limited to unsuccessful login attempts, quick login intervals, unknown devices, odd login hours and password accuracy. These

features will be used to calculate a risk score that will determine whether the login attempt is classified as low risk, medium risk, or high risk. The proposed detection method is inspired from Risk-Based Authentication (RBA) techniques where contextual factors such as user behaviour, login timing, and device information are used to dynamically assess authentication risk (Gunuganti, 2022).

2.2.4 Risk Analysis Module

Based on the calculated risk score, the risk analysis module classifies login attempts into low-risk, medium-risk, or high-risk categories. Several mitigation strategies are triggered depending on the identified risk level.

2.2.5 MFA Verification

Multi-Factor Authentication (MFA) provides an additional layer of security by forcing users to verify a One-Time Password (OTP) following a successful password authentication (Akamai, 2025). Even if an attacker manages to obtain the correct password, access cannot be allowed without OTP verification. The proposed solution draws inspiration from behavioral anomaly detection and adaptive authentication approaches, where MFA enforcement and login behavior analysis help in detecting and reducing suspicious password guessing attempts.

2.2.6 Mitigation Response Mechanism

Depending on the identified risk level, the mitigation response mechanism behaves differently. Low-risk users proceed with conventional OTP verification, medium-risk users experience delayed authentication whilst high-risk users are temporarily blocked to prevent automated password guessing attacks.

2.3 Algorithm/AI/ML Detection Technique

2.3.1 Features Used in Detection

Feature	Description
failed_attempts	Number of failed login attempts
short_interval	Rapid repeated login attempts

unknown_device	Login from unrecognized device
unusual_hour	Login during unusual hours
password_match	Password matching verification

Table 1: Feature Description

2.3.2 Risk Scoring Logic

Feature	Condition	Risk Contribution	Justification
failed_attempts	≥3	+2	Indicates potential brute-force or repeated guessing behaviour
short_interval	< 5 seconds	+2	Suggests automated or scripted login attempts
unknown_device	True	+3	Signifies login from untrusted device
unusual_hour	Login time between 00:00–05:00 (hour < 5)	+1	Represents abnormal access time outside typical user behaviour
password_match	False	+3	Confirms authentication failure consistent with attack attempts

Table 2: Score table

2.3.3 Step-by-Step Algorithm

1. User submits login request
2. Password is verified
3. Login behaviour features are extracted
4. Risk engine calculates risk score
5. Risk level categorised
6. Mitigation response is triggered
7. OTP verification carried out
8. Access granted/denied

2.3.4 Pseudocode

Input: username, password, device_id

1. Receive login request
2. Verify credentials against database
3. Extract behavioural features:
   -failed_attempts
   -login interval
   -device identity
   -login time
   -password correctness
4. Compute risk score:
   score = weighted sum of features
5. IF score >= 5:
   Block user temporarily
   ELSE IF score >=3:
   Delay login + require MFA
   ELSE:
   Proceed with standard MFA
6. Verify OTP
7. Grant or deny access

2.3.5 Flowchart

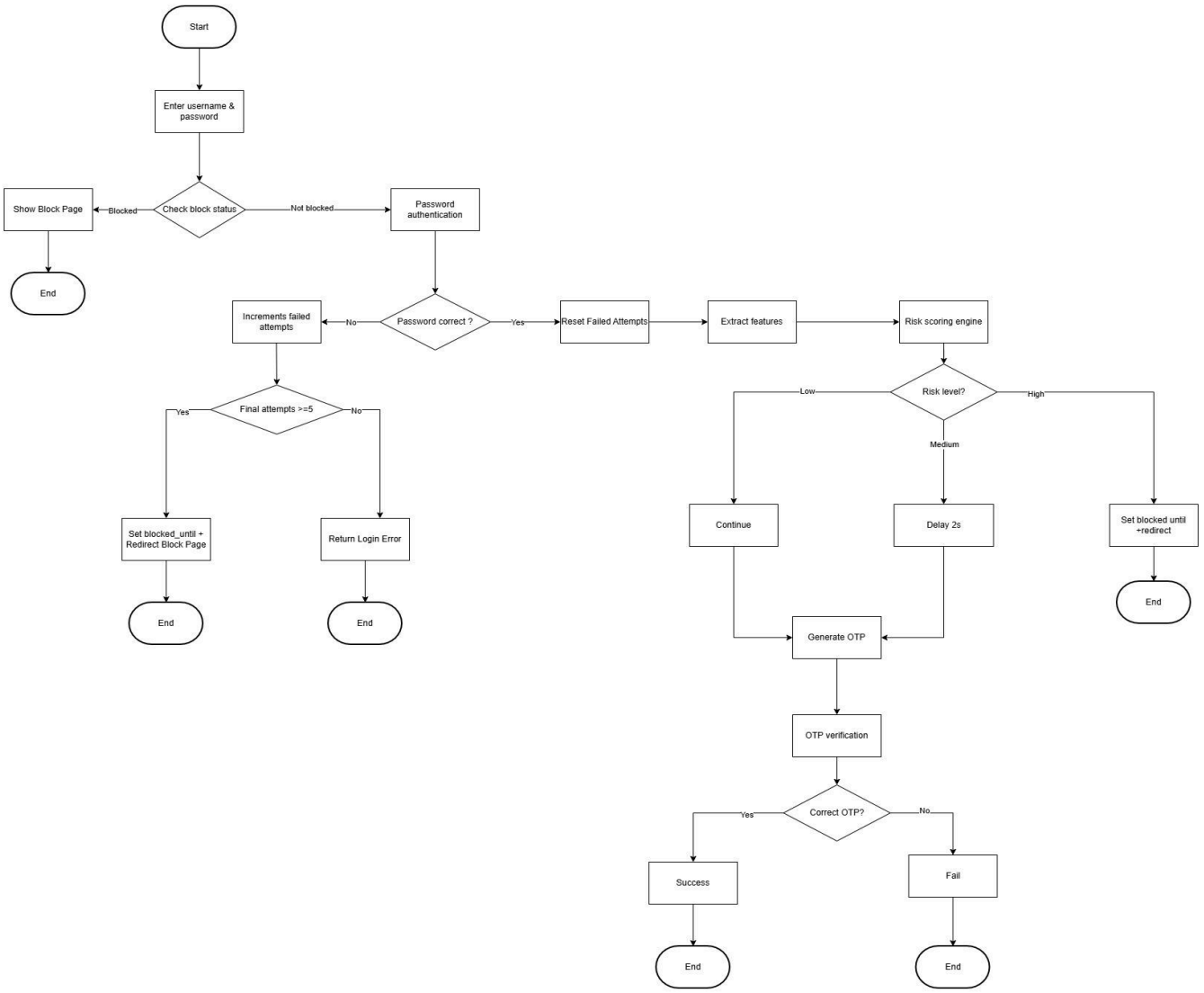


Figure 2 : Flowchart

Based on Figure 2, the system first checks whether the user is blocked. If blocked, the user is redirected to the blocked page and the process stops.

If not blocked, the system verifies the password. Failed attempts are recorded and may lead to temporary blocking.

If the password is correct, behavioural features are extracted and used to calculate a risk score. Based on Figure 2, the system classifies the risk level and applies the appropriate response: low risk proceeds with OTP, medium risk has a short delay before OTP, and high risk results in temporary blocking.

Finally, users who pass OTP verification are granted access.

Question 3 System Implementation

3.1 Development Tools and Technologies

The system was developed using Python and Flask framework to simulate a secure login authentication system with AI/ML-based suspicious login detection.

Technology	Purpose
Python	Main programming language
Flask	Web application framework
HTML/CSS	User interface design
JSON	User and OTP data storage
VS CODE	Development environment

Table 3: Tools and Purpose

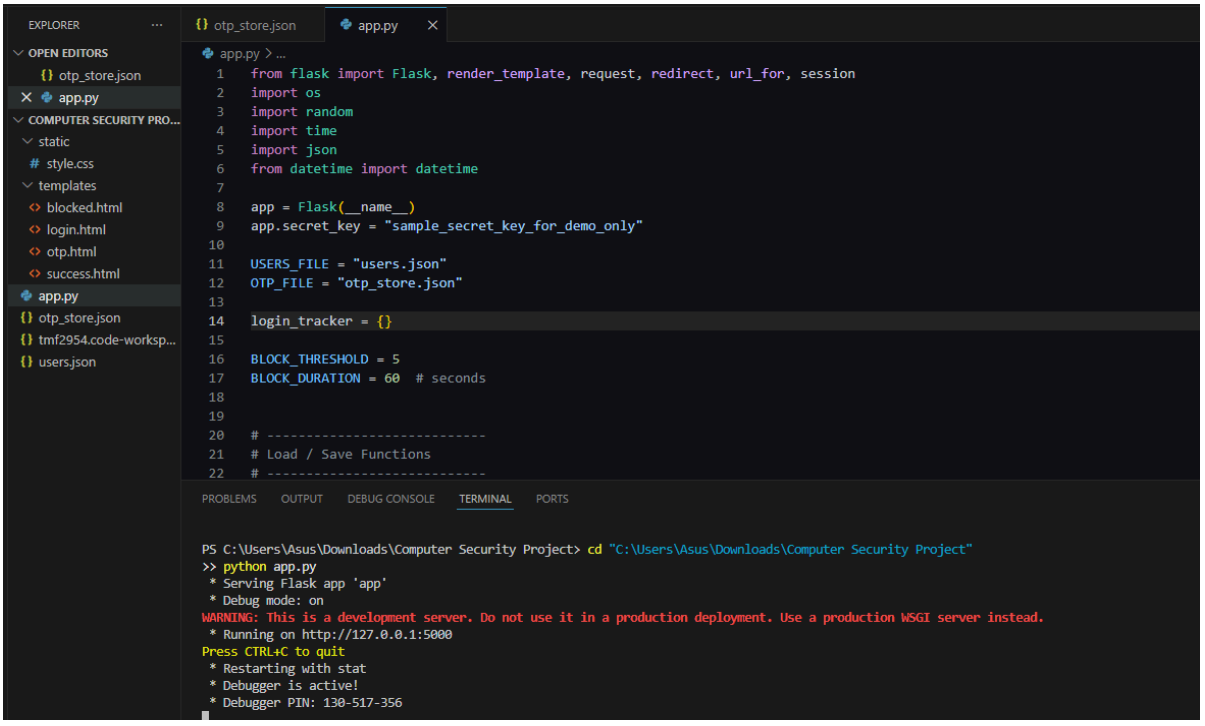


Figure 3: Login Code

3.2 Login Interface Implementation

The system provides a login interface where users are required to enter username, password, and device ID before authentication.

Field	Function
Username	Identify user
Password	Verify identity
Device ID	Detect known or unknown device

Table 4: Field and Function

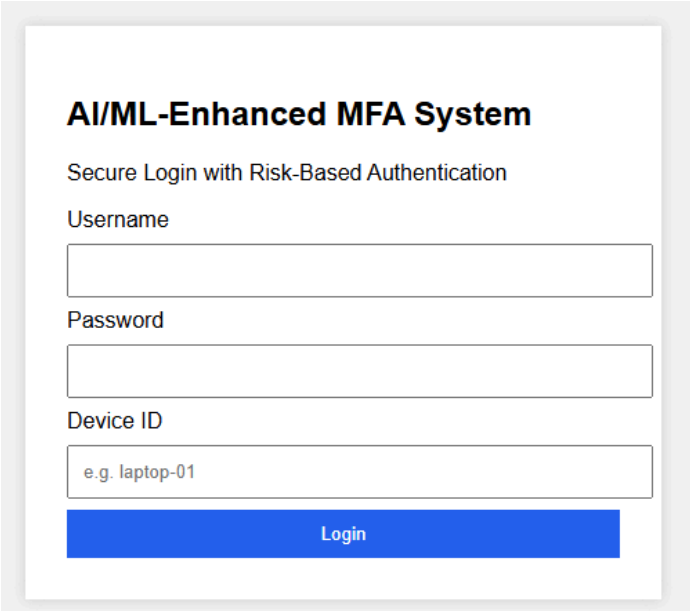


Figure 4: Login Interface

3.3 Password Authentication Implementation

The system implements password authentication by verifying the user's input credentials as shown in Figure 4, against stored records in a JSON database. If the username and password match, the system allows the user to proceed to the next authentication stage (MFA). Otherwise, access is denied and an error message is displayed as shown in Figure 5.

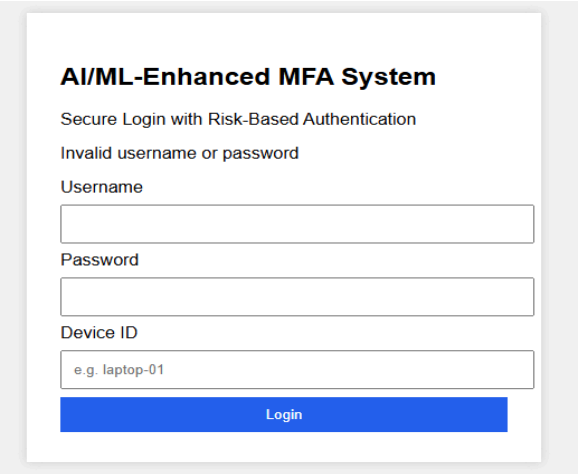


Figure 5: Access denied page

3.4 AI/ML Risk Detection Implementation

The system implements a rule-based AI/ML risk detection engine that analyzes user login behavior.

Feature	**Purpose**
failed_attempts	Detect brute force
shor_interval	Detect rapid login
unknown_device	Detect suspicious device
unusual_hour	Detect abnormal login time

Table 5: Feature and Purpose during Risk Detection Implementation

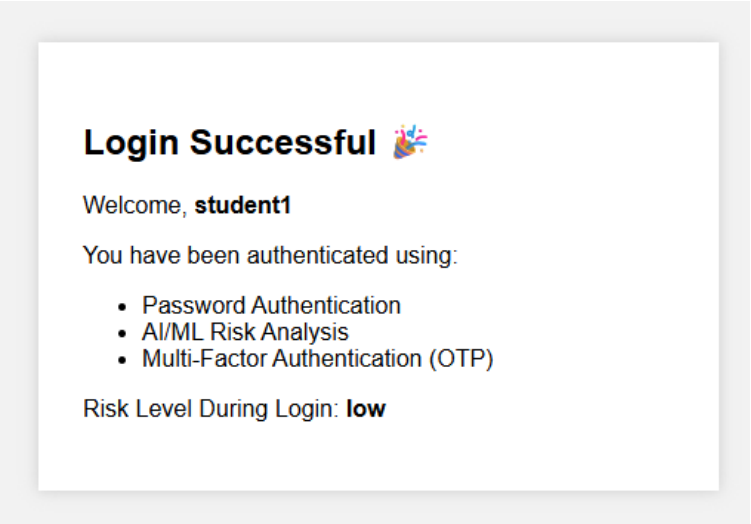


Figure 7: Low Risk Display

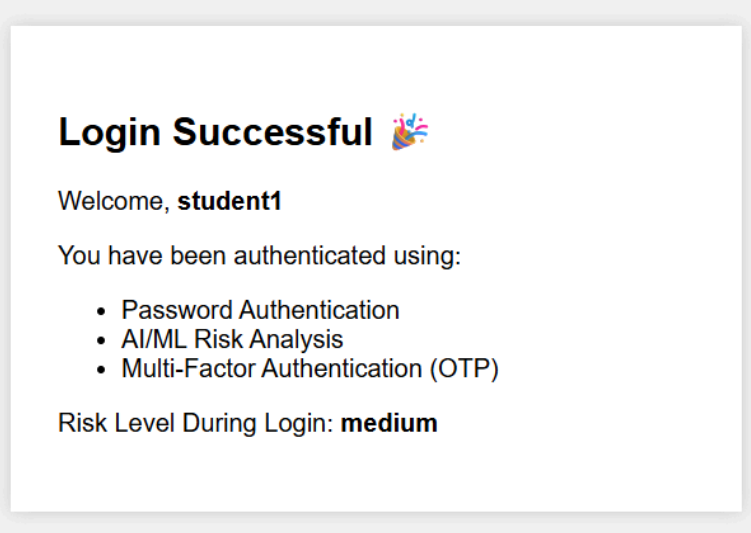


Figure 8: Medium Risk Display

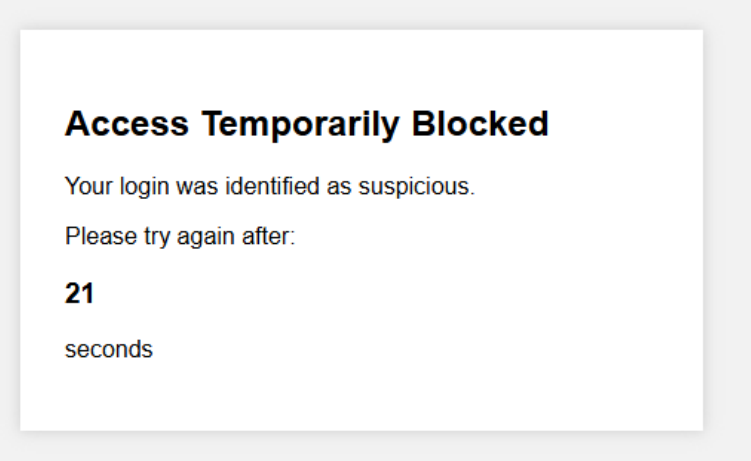


Figure 9: High Risk Temporary Blocked Display

3.5 MFA Verification Implementation

The system implements Multi-Factor Authentication (MFA) using One-Time Password (OTP) verification.After successful password authentication, the system generates a 6-digit OTP and stores it temporarily in otp_store.json.

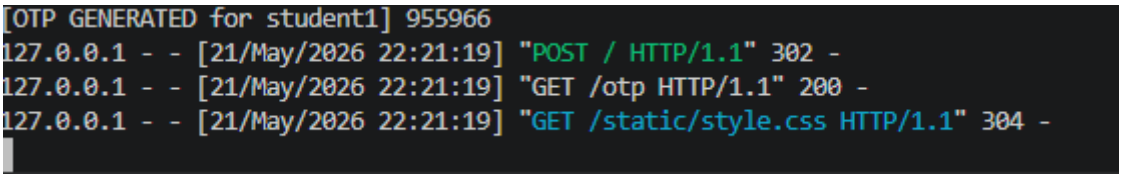


Figure 10: Successful OTP code Generation

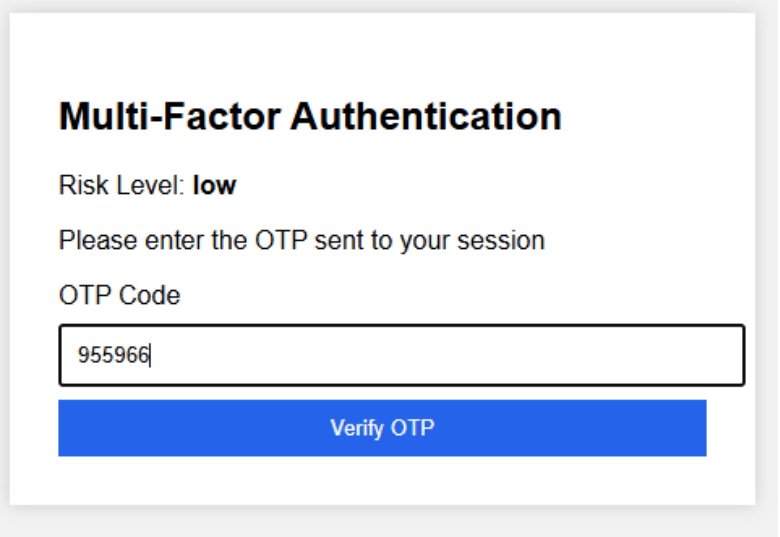


Figure 11: OTP Verification Page

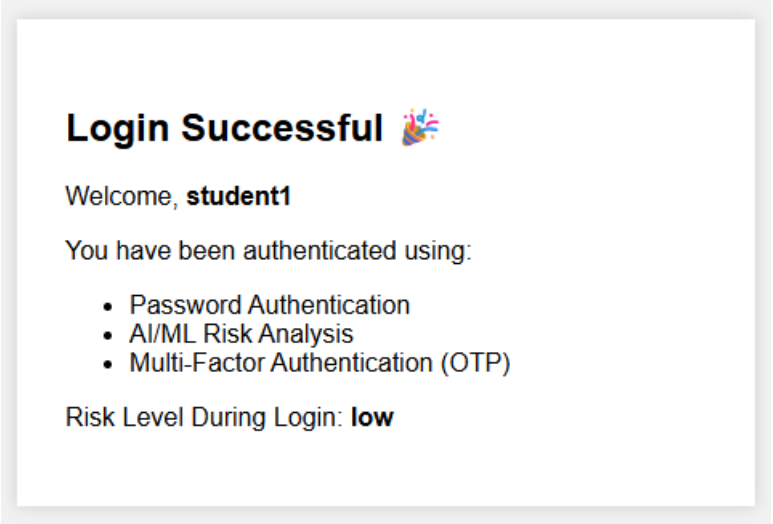


Figure 12: Successful Login Page

3.6 Mitigation Response Implementation

The system implements multiple mitigation mechanisms based on AI/ML risk analysis and authentication behavior to prevent password guessing attacks and suspicious login attempts.

(A) Account Locking (High Risk Mitigation)

When the system detects a high-risk login attempt or excessive failed login attempts, the user account is temporarily locked as shown in Figure 13. This prevents brute-force password guessing attacks.

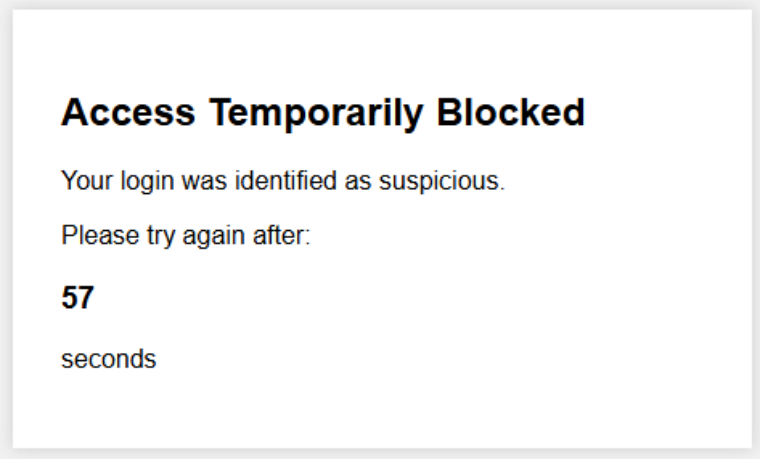


Figure 13: Access Temporarily Blocked Page

(B) Login Delay (Medium Risk Mitigation)

For medium-risk login attempts, the system introduces a delay using time.sleep(2). This slows down automated password guessing attacks and reduces attack efficiency.

(C) Multi-Factor Authentication (OTP)

After successful password authentication and risk evaluation, the system triggers Multi-Factor Authentication (MFA) using a One-Time Password (OTP) as shown in Figure 10. The OTP must be verified before granting access.

(D) Risk-Based Blocking (AI/ML Decision Engine)

The AI/ML-based risk engine evaluates multiple login features such as failed attempts, device recognition, and login timing. If a high-risk score is detected, the system automatically blocks the login attempt as shown in Figure 13.These mitigation techniques work together to ensure that the system can effectively reduce password guessing attacks through blocking, delaying, and multi-factor authentication

Question 4: Testing, Correctness and Effectiveness Analysis

Test 1: Normal Login attempts

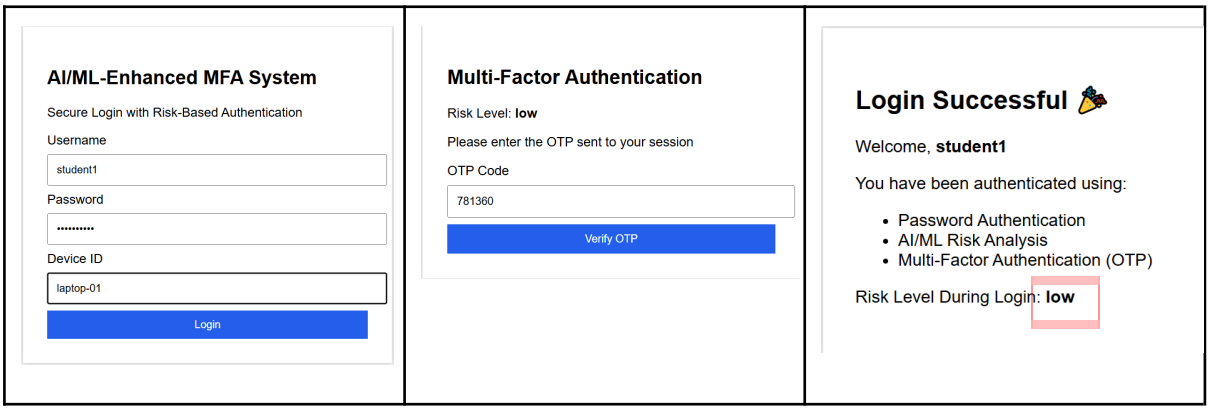


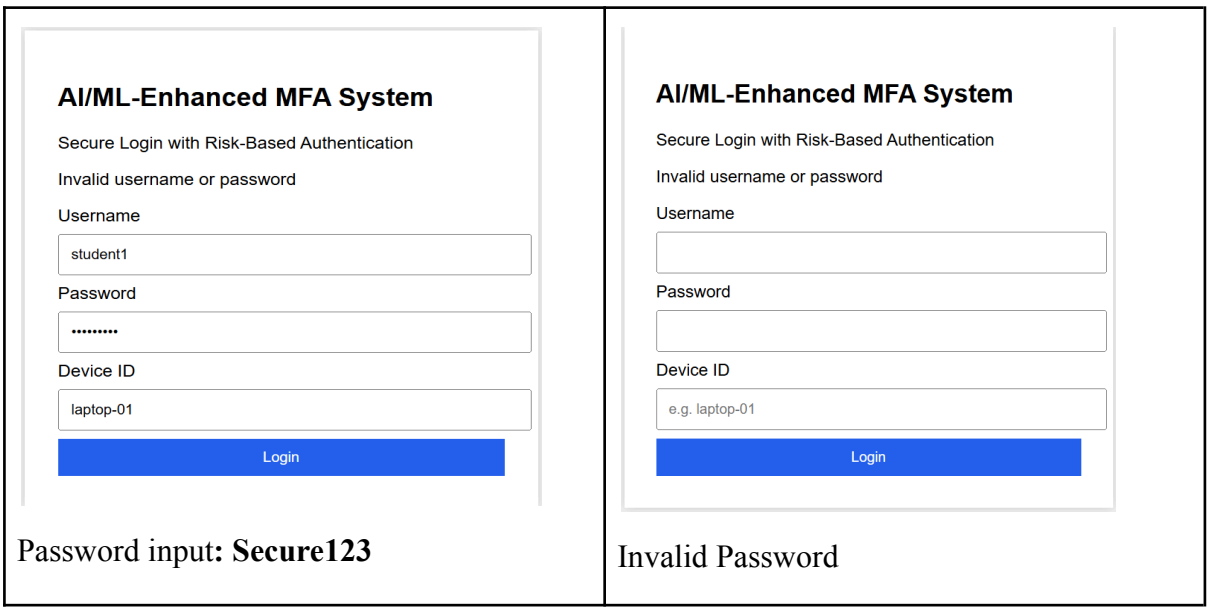
Table 6: Normal Login Attempts

Prompt: Correct Password Attempt after first try

System Response: Successful generation of OTP and Login Successful page

Result: Risk Level during login remains low no mitigation response was triggered.

Test 2: Incorrect Password Attempts



Password input**: Secure123**

Invalid Password

Table 7: Incorrect Password Attempts

Prompt: Incorrect password once

System Response: Generation of relogging in for access

Result: System requires correct information before proceeding to OTP

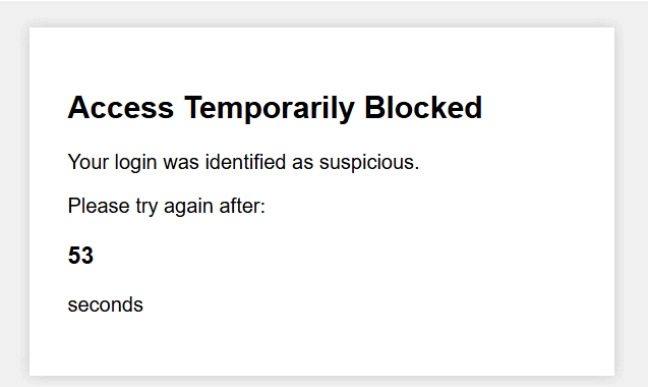


Figure 14: Multiple Incorrect Password Attempts

Prompt: The same wrong password was entered 5 times in a row.
System Response: After the 5th failed attempt, the system blocked the login and showed a temporary lockout message.
Result: Attack mitigated

Test 4: Automated guessing attempts

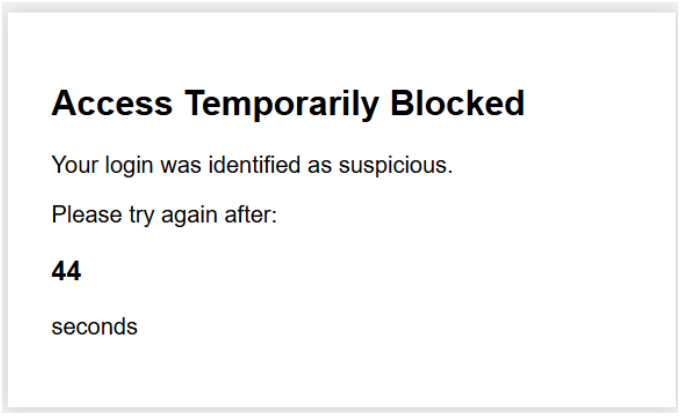


Figure 15: Automated Incorrect Password Attempts

Prompt: Multiple wrong passwords quickly 5 times in a row
System response: The system detects suspicious rapid attempts and raises risk, slowing or blocking the login flow.
Result: Attack mitigated

In Test 3 and Test 4, multiple consecutive failed login attempts and rapid authentication requests triggered the risk detection engine, resulting in elevated risk scores and activation of mitigation responses such as temporary account lockout.

Testing Table-student1

Scenario	Username	Password	Device	System response	Expecte d Result	Result
Normal login	student1	correct	laptop-01	Access granted	Success	Success
Wrong Password	student1	Wrong Password	laptop-01	“Invalid username or password” message shown	Allowed for relogin	Safe
Multiple attempts	student1	Same wrong password	laptop-01	Access Temporarily Blocked	Login Blocked	Attack mitigated
Automated Guessing	student1	Multiple wrong password	laptop-01	Access Temporarily Blocked	Login Blocked	Attack mitigated

Table 8: Testing Table for Student 1

Testing Table-student2

Scenario	Username	Password	Device	System response	Expected Result	Result
Normal login	student2	correct	phone-02	Access granted	Success	Success
Wrong Password	student2	Wrong	phone-02	“Invalid username or password” message shown	Allowed for relogin	Safe
Multiple attempts	student2	Same wrong password	phone-02	Access Temporarily Blocked	Login Blocked	Attack mitigated
Automated Guessing	student2	Multiple wrong password	phone-02	Access Temporarily Blocked	Login Blocked	Attack mitigated

Table 9: Testing Table for Student 2

By using progressive authentication controls based on behavioural risk analysis the system is effective in mitigating numerous password guessing attacks. Brute-force activity is indicated after many repeated failed login attempts which would then increase the risk score. Once the

risk threshold is reached, the system automatically triggers mitigation mechanisms such as temporary account locking or login blocking, preventing further automated password guessing attempts.This prevents password guessing through brute force by blocking repeated wrong guesses before the attackers can succeed. The system also detects suspicious rapid entries, so automated guessing is also mitigated.

Overall, the testing results demonstrate that the proposed authentication system effectively detects and mitigates password guessing attacks under different attack scenarios.

Question 5 Recommendations and Future Improvements

First and foremost, to significantly enhance the threat engine's capabilities, the system should **transition from basic threshold checks into context-aware machine learning feature engineering**. Instead of tracking simple metrics like failed login counts, the engine should evaluate complex contextual combinations, such as geographical velocity for detecting physically impossible travel times between login attempts and time-of-day consistency, against an established baseline. By inserting this dynamic and real-time threat evaluation, it can allow the system to catch low-and-slow automated brute-force attacks that intentionally attempt to slip past traditional rate limits (Megahed et al., 2024).

Secondly, to prevent the heightened sensitivity from burdening legitimate users, **adaptive feedback loops and fuzzy logic thresholds should be deployed**. Rather than triggering abrupt blocks when a user logs in from a new device or location, the system can utilize a privacy-focused risk scoring model to dynamically escalate authentication hurdles like prompting for a push notification or an AI-adjusted alphanumeric code challenge (Fereidouni et al., 2024). This action allows the user to seamlessly verify their identity minimizing false positives and mitigation fatigue.

Thirdly, the improvement to defend against vulnerabilities that persist after the initial entry point is, **to integrate the architecture with continuous behavioral biometrics**. By passively monitoring background interaction habits, for example, keystroke dynamics, mouse trajectory patterns, or touchscreen pressure, the system can establish an ongoing verification layer. If these subtle behavioral markers suddenly shift mid-session, it will show a potential session of hijacking or an unauthorized user taking over an active device. The system can

immediately terminate the session or demand a re-authentication challenge to satisfy required Authenticator Assurance Levels (Temoshok, 2024).

Last but not least, the baseline vulnerabilities of traditional credentials can be permanently eliminated by **migrating to a FIDO2 and WebAuthn-compliant passwordless authentication framework.** By relying on public key cryptography unlocked locally via device-level biometrics such as fingerprint gestures, the system entirely removes passwords from the authentication loop (Yusop et al., 2025). This will neutralize credential-stuffing and dictionary attacks completely, since there are no central user passwords stored on a server to be leaked or even intercepted.

Finally, in order to address the risk of a single point of failure in user data management, the **authentication framework can be combined with decentralized, blockchain-based identity systems**. When utilizing Self-Sovereign Identity (SSI) principles and Decentralized Identifiers (DIDs), user profiles and cryptographic keys will now be anchored to a secure ledger, rather than stored in a centralized repository that might as well be vulnerable. The system can then verify identity claims securely using zero-knowledge proofs (ZKPs), ensuring robust access control without exposing raw and private user data to the risk of a massive repository breach.

References

Fereidouni, H., Hafid, A. S. S., Makrakis, D., & Baseri, Y. (2024). F-RBA: A federated learning-based framework for risk-based authentication. *arXiv*. https://doi.org/10.48550/arxiv.2412.12324

Kim, I. (2026). *Adaptive OTP generation using AI-based risk assessment for context-aware two-factor authentication systems*. ResearchGate. https://www.researchgate.net/publication/401236430

Megahed, A. A., Arnous, M. F., Elmoataz, Y., Moussa, A., Haitham, S., & Hany, M. (2024). Enhanced security through intelligent risk-based authentication: Leveraging big data and machine learning for real-time threat mitigation. *2024 6th Novel Intelligent and Leading Emerging Sciences Conference (NILES)*, 246–249. https://doi.org/10.1109/NILES63360.2024.10753250

Papaspirou, V., Kantzavelou, I., Yigit, Y., Maglaras, L., & Katsikas, S. (2025). A secure blockchain-based MFA dynamic mechanism. *Computers, 14*(12), 550. https://doi.org/10.3390/computers14120550

Sasikumar, K., & Nagarajan, S. (2025). Enhancing cloud security: A multi-factor authentication and adaptive cryptography approach using machine learning techniques. *IEEE Open Journal of the Computer Society*, PP(99), 1–12.

Temoshok, D. (2024). *Digital identity guidelines* (NIST Special Publication 800-63B-4.2pd). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-63b-4.2pd

Yusop, M. I. M., Kamarudin, N. H., Suhaimi, N. H. S., & Hasan, M. K. (2025). Advancing passwordless authentication: A systematic review of methods, challenges, and future directions for secure user identity. *IEEE Access, 13*, 13919–13943. https://doi.org/10.1109/ACCESS.2025.3528960

Use of Generative AI

Generative AI was used in the preparation of this assignment to assist with literature research and structural synthesis. It was also used to discover and format relevant and peer-reviewed academic references within the 2024–2026 year window to ensure the inclusion of up-to-date security research, while also structuring it into clear, precise and cohesive paragraphs. All AI-generated suggestions, technical accuracy checks, and citations were thoroughly reviewed, validated, and integrated manually by us to ensure full compliance with the academic standards and assignment requirements.